
INTERNAL CYBERSECURITY AUDIT REPORT

Botium Toys

Scope, goals, risk assessment, and controls & compliance checklists

Prepared by: Aritz Souto Mimenza

Role: Internal IT Security Auditor

Framework: NIST Cybersecurity Framework (NIST CSF)

Regulations assessed: PCI DSS · GDPR · SOC 1 / SOC 2

Report date: August 12, 2026

Classification: Confidential — internal use

1. Executive summary

Botium Toys' IT department commissioned this internal audit in response to the growth of its online marketplace, which now serves customers in the United States and the European Union. The goal is to give an overview of the risks and potential penalties arising from the current state of the company's security posture, and to determine which controls and compliance best practices should be implemented.

The audit was structured using the NIST Cybersecurity Framework. It reviewed the scope, goals, and risk assessment prepared by the IT manager, and completed the controls and compliance checklists (PCI DSS, GDPR, and SOC 1/2).

Key finding: Botium Toys carries a high risk (8/10). The most serious gaps involve regulated data — unrestricted access to cardholder information and PII, and no encryption — which together breach PCI DSS and GDPR. The absence of backups and a recovery plan also threatens business continuity.

RISK SCORE: 8 / 10 — HIGH

Driven by missing key controls and incomplete adherence to compliance best practices. The impact of losing an asset is amplified because the IT department has no inventory identifying which assets are at risk.

2. Audit scope and goals

Scope: the entire security program at Botium Toys, including employee equipment and devices, the internal network, and company systems. It covers a review of existing assets and of the controls and compliance practices already in place.

Goals: assess existing assets and complete the controls and compliance checklists to determine which measures should be implemented to improve the company's security posture.

Assets currently managed by the IT department

- On-premises equipment for in-office business needs.
- Employee equipment: end-user devices (desktops/laptops, smartphones), remote workstations, headsets, cables, keyboards, mice, docking stations, and surveillance cameras.
- Products available for retail sale on site and online, stored in the adjoining warehouse.
- Management of systems, software, and services: accounting, telecommunications, database, security, ecommerce, and inventory.
- Internet access, internal network, and data retention and storage.
- Maintenance of legacy (end-of-life) systems that require human monitoring.

3. Risk assessment

Asset management is currently inadequate. Botium Toys does not have all the proper controls in place and may not be fully compliant with U.S. and international regulations. Under the first NIST CSF function — Identify — the company will need to dedicate resources to identifying and classifying its assets and to determining the impact their loss would have on business continuity.

Potential impact: medium, because the IT department does not know which assets would be at risk. The risk of fines from governing bodies is high, given the missing controls and the incomplete adherence to

compliance best practices that keep critical data private and secure.

Identified strengths and deficiencies

Current strengths	Deficiencies / gaps
✓ Firewall that filters traffic based on an appropriately defined set of security rules.	✗ All employees can access internal data, including cardholder data and PII/SPII.
✓ Antivirus software installed and monitored regularly.	✗ No encryption is used on credit card data.
✓ Data integrity and availability controls in place.	✗ Least privilege and separation of duties have not been implemented.
✓ Plan to notify E.U. customers within 72 hours of a breach (GDPR).	✗ No intrusion detection system (IDS) is in place.
✓ Privacy policies developed, documented, and enforced.	✗ No disaster recovery plans and no backups of critical data.
✓ Adequate physical security: locks, up-to-date CCTV, and working fire detection and prevention.	✗ Password policy is minimal, with no centralized management system.
	✗ Legacy-system maintenance lacks a regular schedule and clear intervention methods.

4. Controls checklist

Does Botium Toys currently have this control in place? (Yes / No)

Yes	No	Control / Best practice
	✓	Least privilege
	✓	Disaster recovery plans
✓		Password policies <i>(in place but inadequate)</i>
	✓	Separation of duties
✓		Firewall
	✓	Intrusion detection system (IDS)
	✓	Backups
✓		Antivirus software
✓		Manual monitoring and maintenance of legacy systems <i>(in place but inadequate)</i>
	✓	Encryption
	✓	Password management system
✓		Locks (offices, storefront, warehouse)
✓		Closed-circuit television (CCTV) surveillance
✓		Fire detection and prevention

5. Compliance checklist

Does Botium Toys currently adhere to this compliance best practice? (Yes / No)

5.1 Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Control / Best practice
	✓	Only authorized users have access to customers' credit card information.
	✓	Credit card information is stored, accepted, processed, and transmitted internally in a secure environment.
	✓	Data encryption procedures secure credit card transaction touchpoints.
	✓	Secure password management policies are adopted.

5.2 General Data Protection Regulation (GDPR)

Yes	No	Control / Best practice
	✓	E.U. customers' data is kept private and secure.
✓		A plan is in place to notify E.U. customers within 72 hours of a breach.
	✓	Data is properly classified and inventoried.

Yes	No	Control / Best practice
✓		Privacy policies and processes are enforced to document and maintain data.

5.3 System and Organization Controls (SOC 1 / SOC 2)

Yes	No	Control / Best practice
	✓	User access policies are established.
	✓	Sensitive data (PII/SPII) is confidential and private.
✓		Data integrity ensures data is consistent, complete, accurate, and validated.
✓		Data is available to individuals authorized to access it.

6. Recommendations

Recommendations are prioritized by risk level, so the IT manager can pass them to stakeholders to reduce risk to assets and improve the security posture.

Priority	Recommendation
Critical	Encrypt regulated data and enforce access control. Every employee can currently reach cardholder data and PII/SPII, and no encryption is in use. This breaches PCI DSS and GDPR at the same time and exposes the company to fines and data breaches. Implement encryption (at rest and in transit) and apply least privilege and separation of duties so that access is restricted to those who need it.
High	Secure business continuity. There are no backups and no disaster recovery plan; a single incident such as ransomware or a hardware failure could cause the irreversible loss of critical data. Establish regular backups and document a recovery plan.
Medium	Add the missing control layers. Install an intrusion detection system (IDS) to complement the existing firewall. Deploy a centralized password management system and strengthen the policy (at least eight characters, with letters, numbers, and symbols), which would also cut the password-reset tickets that hurt productivity.
Medium	Govern the assets (NIST CSF Identify function). Classify and inventory the assets and determine the impact their loss would have on business continuity. The absence of this inventory is what keeps residual risk high. Also set a formal maintenance schedule for the legacy systems.

Methodology note

When presenting these findings to leadership, it helps to frame the gaps in terms of business risk — regulatory fines, data loss, and operational disruption — rather than technical terms alone, since that is what supports budget allocation. The existing strengths need no new investment, only ongoing maintenance.

Auditor's sign-off

This report reflects the state of Botium Toys' security posture as observed at the time of the audit, assessed against the NIST CSF and the PCI DSS, GDPR, and SOC 1/2 requirements listed above.

Aritz Souto Mimenza
Internal IT Security Auditor

Date : 12.08.2026